

# 모의해킹 상세 보고서

과업명

유기견 성향 분석 기반 추천 서비스 구축 사업 및 정보보호 체계  
강화사업

2026년 7월 16일

## 개 정 이 력

[illegible]

## 목차

|                                                  |           |
|--------------------------------------------------|-----------|
| <b>1. 모의해킹 수행 정보 .....</b>                       | <b>4</b>  |
| 1.1. 배경 및 목적 .....                               | 4         |
| 1.2. 수행 일정 및 수행 내역 .....                         | 4         |
| 1.3. 수행 대상 .....                                 | 5         |
| 1.4. 점검 도구 .....                                 | 5         |
| <b>2. 모의해킹 결과 .....</b>                          | <b>5</b>  |
| 2.1. 총평 .....                                    | 5         |
| 2.2 결과 요약 .....                                  | 6         |
| <b>3. 취약점 상세 내용.....</b>                         | <b>6</b>  |
| 3.1. 세션 고정 .....                                 | 6         |
| 3.2. SQL Injection .....                         | 9         |
| 3.3. IDOR(주문정보조회) .....                          | 14        |
| 3.4. IDOR(장바구니 수량 변경) .....                      | 16        |
| 3.5. IDOR(회원정보수정) .....                          | 19        |
| 3.6. 파일 업로드 취약점 (Unrestricted File Upload) ..... | 22        |
| 3.6. CSRF.....                                   | 26        |
| <b>4. 보안 권고안 .....</b>                           | <b>29</b> |
| 4.1. 세션 고정 .....                                 | 29        |
| 4.2. SQL Injection .....                         | 29        |

|                       |    |
|-----------------------|----|
| 4.3. IDOR .....       | 30 |
| 4.4. 파일 업로드 취약점 ..... | 30 |
| 4.5 CSRF.....         | 30 |

## 1. 모의해킹 수행 정보

### 1.1. 배경 및 목적

- 웹 애플리케이션에 대한 모의 해킹을 수행한 후 발견된 취약점에 대한 대응 방안을 제시함으로써 차후 발생할 수 있는 침해 사고를 예방하고 정보 보호 수준을 향상할 수 있는 대책을 수립하는 데 기여하는 것을 목적으로 합니다.
- 본 사업은 유기견 입양 추천 서비스의 안정적인 운영환경 구축 및 보안 강화를 위해 모의해킹을 수행하는 것을 목적으로 합니다.
  - 선제적 취약점 도출: 실제 해커 관점의 시나리오 기반 모의해킹을 통해 서비스 및 인프라의 잠재적 보안 취약점 식별
  - 침해사고 예방 및 대응력 강화: 식별된 취약점에 대한 실효성 있는 보안 대책(Patch)을 수립하여 외부 위협으로부터 시스템 보호
  - 안전한 서비스 환경 확보: 사용자 개인정보 보호 체계를 공고히 하고, 중단 없는 안정적인 유기견 입양 추천 서비스 환경 구축

### 1.2. 수행 일정 및 수행 내역

|   | 수행 날짜     | 수행 내역             |
|---|-----------|-------------------|
| 1 | 26.06.26  | SQL Injection     |
| 2 | 26.06.27  | IDOR(주문정보조회)      |
| 3 | 26.06. 27 | IDOR(장바구니 수량 변경)  |
| 4 | 26.06.28  | IDOR(마이페이지 정보 변경) |
| 5 | 26.06.29  | Session Fixation  |
| 6 | 26.06.30  | Web Shell(상품 등록)  |

|   |          |             |
|---|----------|-------------|
| 7 | 26.07.01 | CSRF(마이페이지) |
|---|----------|-------------|

### 1.3. 수행 대상

| NO | 페이지      | 사이트명(URL)                                   |
|----|----------|---------------------------------------------|
| 1  | 로그인      | http://www.dddm.com/ddm_php/login.php       |
| 2  | 마이페이지    | http://www.dddm.com/ddm_php/mypage.php      |
| 3  | 상품 게시판   | http://www.dddm.com/ddm_php/shop_list.php   |
| 4  | 상품 상세페이지 | http://www.dddm.com/ddm_php/shop_detail.php |
| 5  | 장바구니     | http://www.dddm.com/ddm_php/cart.php        |
| 6  | 주문 상세페이지 | http://www.dddm.com/ddm_php/order_view.php  |
| 7  | 상품 등록페이지 | http://www.dddm.com/ddm_php/product_add.php |

### 1.4. 점검 도구

- 본 모의해킹을 수행하면서 사용된 도구는 아래 표와 같다.

| 도구 이름      | 용도  | 사이트                          |
|------------|-----|------------------------------|
| Burp Suite | 프록시 | http://portswigger.net/Burp/ |

## 2. 모의해킹 결과

### 2.1. 총평

- 본 시스템은 로그인에 1개, 메인 페이지에 1개, 상품게시판에 4개, 마이 페이지에 2개, 상품등록페이지에 1개 총 9개의 취약점이 존재합니다.
- 세션고정, SQL Injection, IDOR, 파일 업로드 등의 취약점이 존재하며, 세션고정 취약점으로는 계정 탈취, SQL Injection 취약점으로는 로그인 처리, DB 정보 탈취, IDOR 취약점으로는 타 회원 주문 정보 확인 및 변경, 장바구니 수량 변경, 파일 업로드 취약점으로는 웹 셸로 사용자의 쿠키 탈취 등의 공격 위험이 있습니다.

## 2.2 결과 요약

| NO | 대상     | 취약점                   | 위치                                               |
|----|--------|-----------------------|--------------------------------------------------|
| 1  | 로그인    | 세션고정<br>SQL Injection | http://www.dddm.com/ddm_php/login_proc.php       |
| 2  | 주문정보   | IDOR                  | http://www.dddm.com/ddm_php/order_view.php       |
| 3  | 장바구니   | IDOR                  | http://www.dddm.com/ddm_php/cart.php             |
| 4  | 회원정보수정 | IDOR                  | http://www.dddm.com/ddm_php/mypage_update.php    |
| 5  | 상품 등록  | File Upload           | http://www.dddm.com/ddm_php/product_add_proc.php |

## 3. 취약점 상세 내용

### 3.1. 세션 고정

| 구분          | 설명                                                                                                                                                                                                                                                                     |                                   |               |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|---------------|
| 발견URL       | URL                                                                                                                                                                                                                                                                    | 파라미터                              | 메뉴            |
|             | http://www.dddm.com/ddm_php/login_proc.php<br>(proc/login_proc.php)                                                                                                                                                                                                    | user_id, user_pw<br>session value | 메인 페이지 -> 로그인 |
| 취약점<br>상세내역 | <p>로그인 처리 과정에서 인증 성공 후 새로운 세션 ID가 재발급되지 않고 기존 세션 ID가 그대로 유지되는 것을 확인하였다. 이 경우 공격자가 사전에 특정 세션 ID를 피해자 브라우저에 고정시킨 뒤 피해자가 해당 세션으로 로그인하면 공격자는 동일한 세션 ID를 이용하여 피해자 계정으로 접근할 수 있다.</p> <p>서버가 로그인 성공 시 session_regenerate_id()와 같은 세션 재발급 처리를 수행하지 않아 세션 고정 공격이 가능한 상태이다.</p> |                                   |               |
| 시나리오        | <p>세션ID가 포함된 링크 메일 전송</p> <p>공격자</p> <p>로그인 정보가 저장된 세션ID</p> <p>피해자</p> <p>로그인</p> <p>권한 부여</p> <p>DataBase</p>                                                                                                                                                        |                                   |               |
| 재현<br>절차    | <p>1. 로그인 전 세션 ID 확인</p> <p>브라우저 개발자 도구의 Storage/Cookie 항목에서 로그인 전 발급된 PHPSESSID 값을 확인하였다.</p>                                                                                                                                                                         |                                   |               |

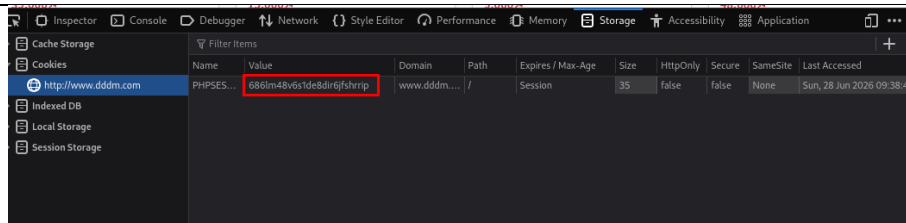


그림 3.1-1. 로그인 전 세션 ID 확인

## 2. 로그인 후에도 동일한 세션 ID 유지 확인

동일한 브라우저에서 정상 계정으로 로그인한 후에도 기존 PHPSESSID 값이 변경되지 않고 그대로 유지되는 것을 확인하였다.

이를 통해 인증 전 세션과 인증 후 세션이 분리되지 않는 문제가 존재함을 확인하였다.

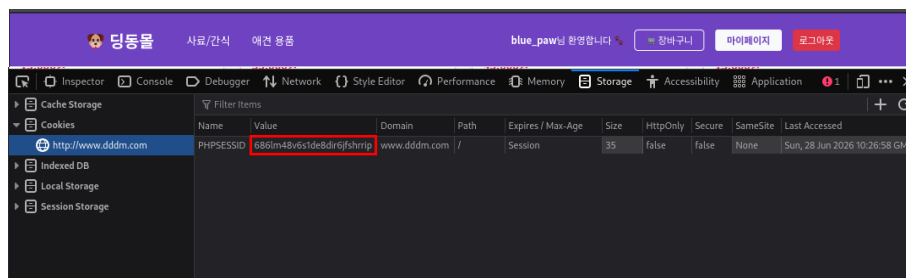


그림 3.1-2. 로그인 후에도 동일한 세션 ID 유지

## 3. 공격자가 지정한 세션 ID 사용

시크릿 창에서 공격자가 임의로 설정한 세션 ID를 쿠키에 입력한 후 로그인 페이지에 접근하였다.

이후 피해자가 해당 세션으로 로그인하면, 해당 세션 ID가 인증된 세션으로 전환된다.

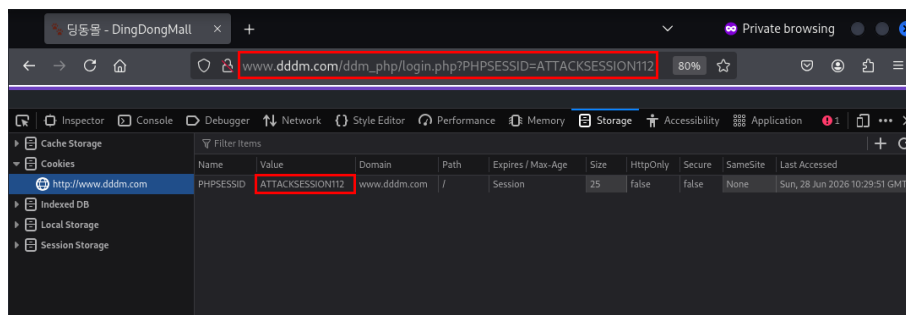


그림 3.1-3. 공격자가 지정한 세션 ID 사용

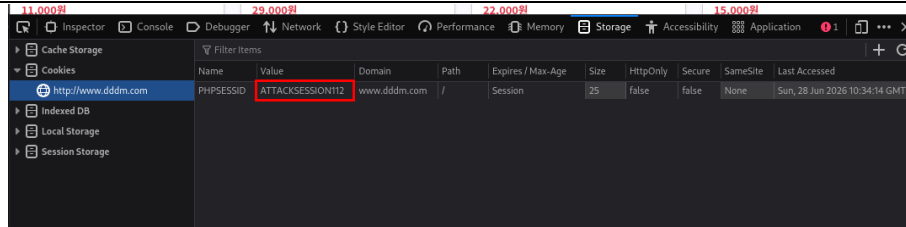


그림 3.1-4. 해당 세션 ID 가 인증된 세션으로 전환

#### 4. 동일 세션 ID를 이용한 계정 접근 확인

공격자가 동일한 PHPSESSID 값을 자신의 브라우저에 설정한 후 페이지를 새로고침하자, 피해자 계정으로 로그인 된 상태가 유지되는 것을 확인하였다. 따라서 세션 고정 취약점을 통해 비인가자가 피해자 계정에 접근할 수 있음을 확인하였다.

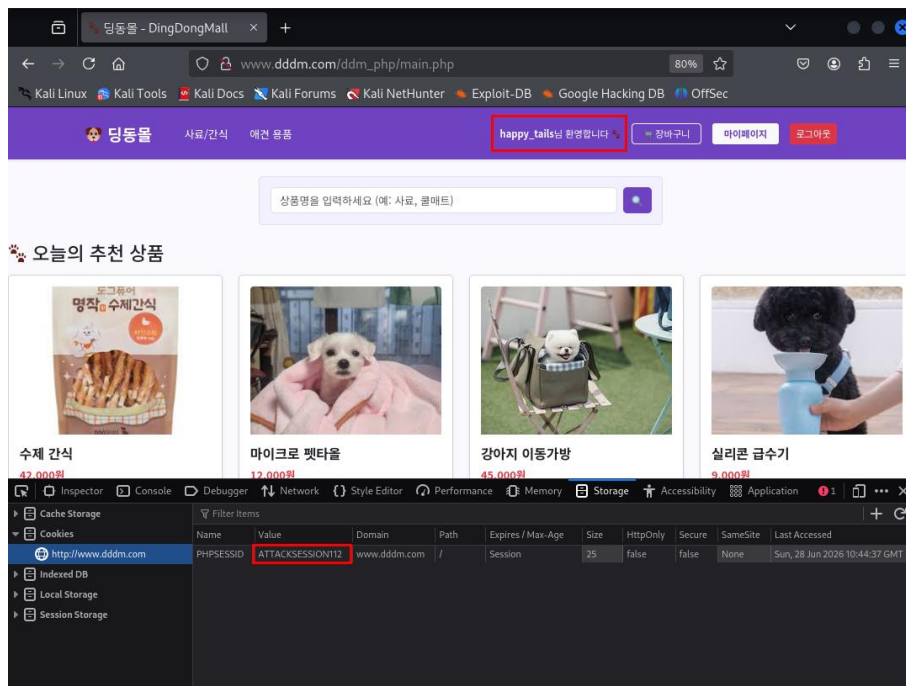


그림 3.1-5. 동일 세션 ID 를 이용한 계정 접근 확인

| 영향도 | 영향       | 설명                           |
|-----|----------|------------------------------|
|     | 계정 탈취    | 피해자가 로그인한 세션을 공격자가 그대로 사용 가능 |
|     | 개인정보 노출  | 마이페이지, 주문정보 등 사용자 정보 열람 가능   |
|     | 권한 오용    | 피해자 권한으로 상품 구매, 정보 수정 등 가능   |
|     | 추가 공격 연계 | IDOR, CSRF 등 다른 취약점과 결합 가능   |



| 발생<br>원인 | 원인          | 설명                                  |
|----------|-------------|-------------------------------------|
|          | 세션 재발급 미흡   | 로그인 성공 후 새로운 세션 ID를 발급하지 않음         |
|          | 기존 세션 유지    | 인증 전 세션이 인증 후에도 그대로 사용됨             |
|          | 세션 보안 옵션 부족 | HttpOnly, Secure, SameSite 설정 미흡 가능 |

## 3.2. SQL Injection

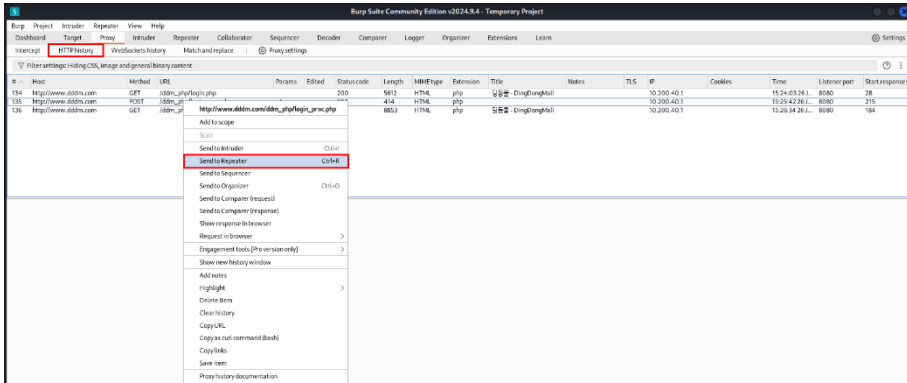
| 구분          | 설명                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                  |               |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|---------------|
| 발견URL       | URL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | 파라미터             | 메뉴            |
|             | http://www.dddm.com/ddm_php/login_proc.php<br>(proc/login_proc.php)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | user_id, user_pw | 메인 페이지 -> 로그인 |
| 취약점<br>상세내역 | login_proc.php에서 사용자가 입력한 user_id와 user_pw 값을 별도의 검증이나 정제 없이 동적 쿼리로 처리하고 있어, 악의적인 SQL 구문을 삽입할 경우 인증을 우회하여 정상적인 로그인 처리가 가능합니다.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                  |               |
| 시나리오        | <div style="display: flex; justify-content: space-around; align-items: center;"> <div style="text-align: center;"> <br/> <b>공격자</b> </div> <div style="text-align: center;"> <p>악의적인 SQL 쿼리문 주입</p> <br/> MS SQL instance </div> <div style="text-align: center;"> <br/> <b>웹 서버</b> </div> <div style="text-align: center;"> <p>쿼리문 변조</p> <br/> MS SQL instance </div> <div style="text-align: center;"> <br/> <b>DataBase</b> </div> </div> <p style="text-align: center;">인증 우회 및 데이터 유출</p> |                  |               |
| 재현<br>절차    | <p>1. 패킷 캡처 및 전달</p> <p>Burp Suite 프록시 도구를 사용하여 로그인 처리 페이지(login_proc.php)로 전송되는 HTTP 요청 패킷을 캡처한 후 Repeater 기능으로 전달하였다.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                  |               |

그림 3.2-1. 패킷 Repeater 로 전달

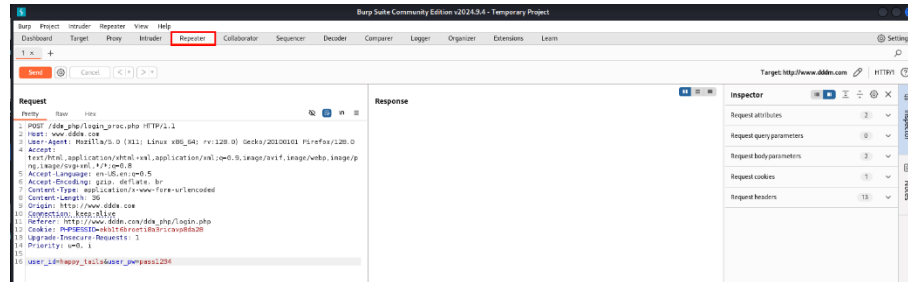


그림 3.2-2. 로그인 처리 페이지(login\_proc.php)로 전송되는 HTTP 요청 패킷

## 2. 파라미터 취약점 확인

user\_id 변수에 싱글 쿼터(')를 주입하여 전송했을 때, MariaDB 서버의 SQL 구문 에러 메시지(You have an error in your SQL syntax...)가 노출되는 것을 보고 SQL Injection이 가능함을 확인하였다.

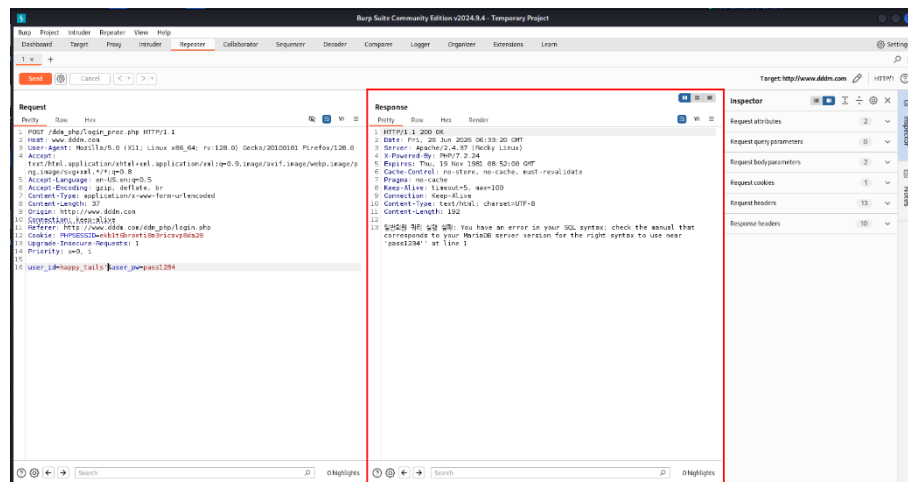


그림 3.2-3. 파라미터 취약점 확인

## 3. 로그인 인증 우회 성공

user\_id에 ' OR '1'='1' -- 을 입력하고 패킷을 전송하자, 비밀번호 검증을 우회하고 정상 로그인에 성공하여 메인 페이지(main.php)로 리다이렉트(HTTP/1.1 200 OK, alert('환영합니다!'))되는 것을 확인하였다.

그림 3.2-4. user\_id 에 ' OR '1'='1' -- 을 입력

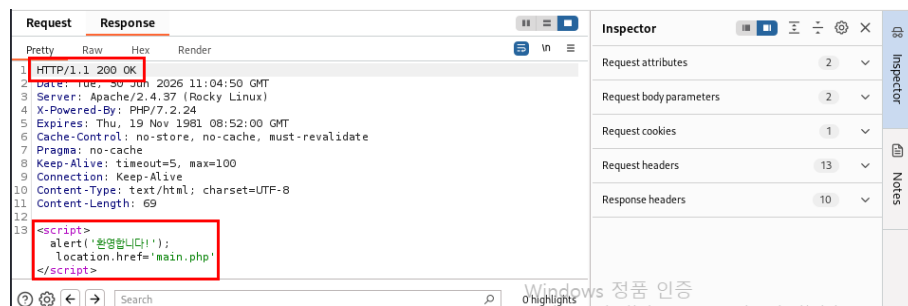


그림 3.2-5. 로그인 인증 우회 성공

#### 4. Blind SQL Injection을 통한 데이터베이스명 탈취

참/거짓 반응을 이용하는 Boolean-Based Blind 방식을 수행하였습니다. ' OR '1'='1' AND SUBSTRING(database(), 1, 1)='a'-- 입력 시에는 로그인 실패 메시지가 발생했으나, 마지막 글자를 'd'로 입력했을 때는 참이 되어 로그인에 성공하였습니다. 이를 통해 데이터베이스 이름의 첫 글자가 'd'임을 알아내고 전체 DB 내용을 추출할 수 있음을 증명하였다.

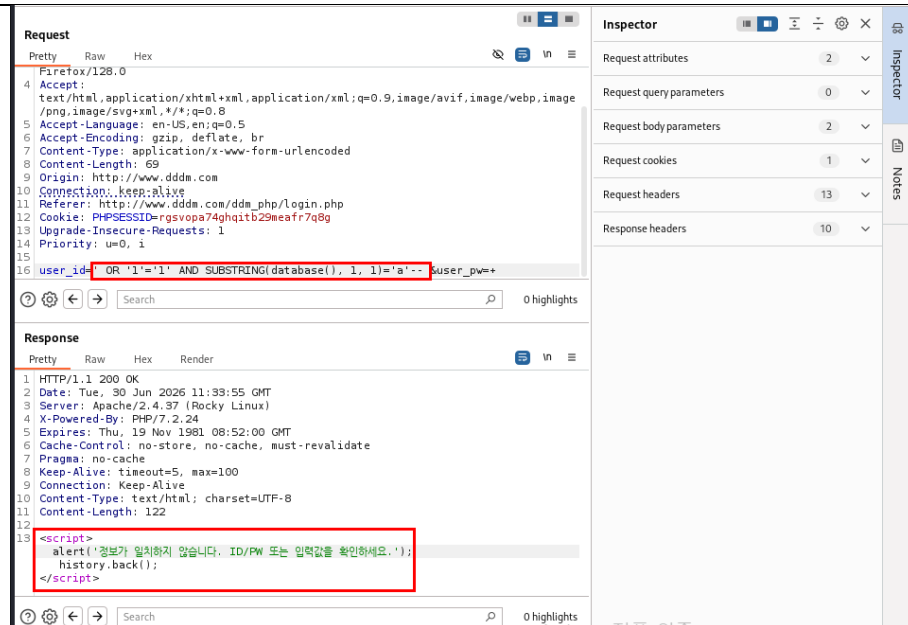


그림 3.2-6. ' OR '1'='1' AND SUBSTRING(database(), 1, 1)='a'-- 입력 시

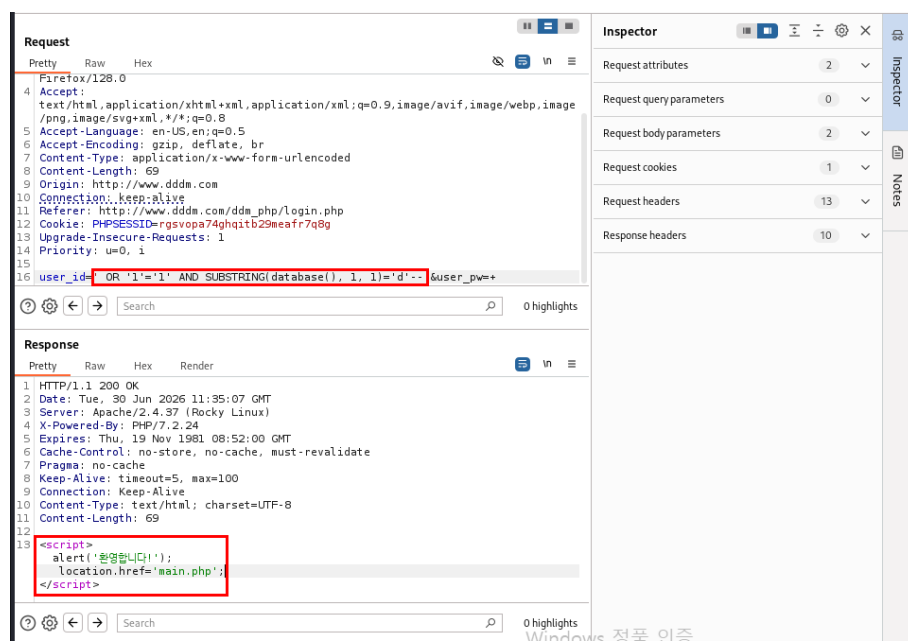


그림 3.2-7. ' OR '1'='1' AND SUBSTRING(database(), 1, 1)='d'-- 입력 시

## 5. 컬럼의 개수 찾기

ORDER BY 절의 숫자를 늘려가며 질의하는 과정에서 ORDER BY 10-- 은 정상 동작했으나, ORDER BY 13-- 을 입력했을 때 Unknown column '13' in 'order clause' 에러가 발생하는 것을 통해 해당 쿼리가 사용하는 컬럼의 개수가 12개임을 파악하였다.

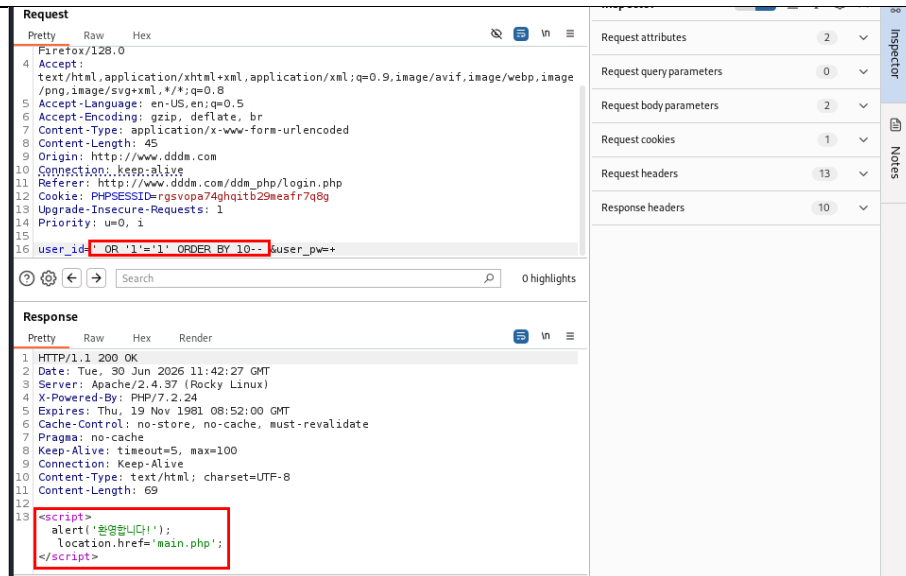


그림 3.2-8. ORDER BY 10-- 입력 시

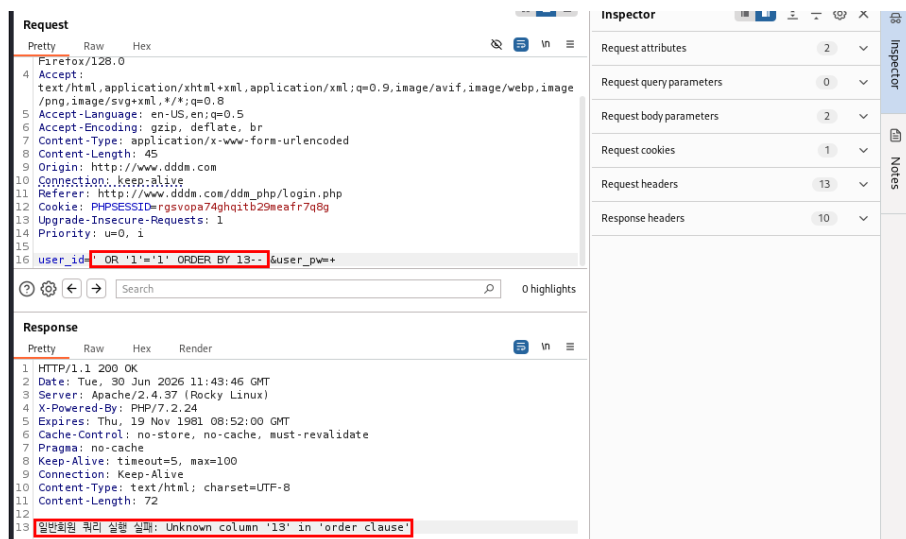


그림 3.2-9. ORDER BY 13--입력 시

| 영향도 | 영향                | 설명                                                                     |
|-----|-------------------|------------------------------------------------------------------------|
|     | 인증 우회 및 계정 도용     | 비밀번호를 모르더라도 임의의 계정(예: 관리자)으로 로그인 가능                                    |
|     | 데이터베이스 정보 탈취 및 조작 | Blind 기술 등을 활용하여 내부 DB에 저장된 다른 회원들의 개인정보, 시스템 테이블 정보를 무단으로 열람하거나 변조 가능 |

| 발생<br>원인 | 원인              | 설명                                                          |
|----------|-----------------|-------------------------------------------------------------|
|          | 동적 SQL 구문 사용    | 입력 값을 쿼리 구조와 분리하지 않고 문자열 결합 방식으로 SQL문을 생성                   |
|          | 입력 값 검증 및 정제 미흡 | 싱글 쿼터(') 등 SQL 구문 구조를 변화시킬 수 있는 특수문자에 대한 필터링이나 이스케이프 처리가 부재 |

### 3.3. IDOR(주문정보조회)

| 구분          | 설명                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |          |        |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|--------|
| 발견URL       | URL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | 파라미터     | 메뉴     |
|             | http://www.dddm.com/ddm_php/order_view.php<br>(order_view.php)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | order_id | 주문정보조회 |
| 취약점<br>상세내역 | 시스템이 사용자가 요청한 order_id가 실제 데이터베이스에 존재하는지 체크할 뿐, "해당 주문 내역이 현재 로그인 된 사용자(세션)의 소유인가?"에 대한 권한 검증 로직이 전혀 존재하지 않습니다. 이로 인해 파라미터 값을 임의로 변경하여 타인의 주문 데이터를 변조·열람할 수 있습니다.                                                                                                                                                                                                                                                                                                                                                                                                                               |          |        |
| 시나리오        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |          |        |
| 재현<br>절차    | <p>1. DB_BR_Rocky 서버에서 현재 ddm_order table 확인</p> <pre> MariaDB [ddm_db]&gt; SELECT order_id, user_id, order_price, order_status FROM ddm_order; +-----+-----+-----+-----+   order_id   user_id   order_price   order_status   +-----+-----+-----+-----+   1   happy_tails   9000   배송준비중     2   happy_tails   28000   배송준비중     3   blue_paw   48000   배송준비중     4   blue_paw   85000   배송준비중   +-----+-----+-----+-----+ 4 rows in set (0.147 sec) </pre> <p>그림 3.3-1. ddm_order table</p> <p>2. 본인 주문 페이지 접근<br/>blue_paw 계정으로 로그인한 상태에서 본인의 주문 상세페이지(order_view.php?order_id=4)에 접근하였다.</p> |          |        |

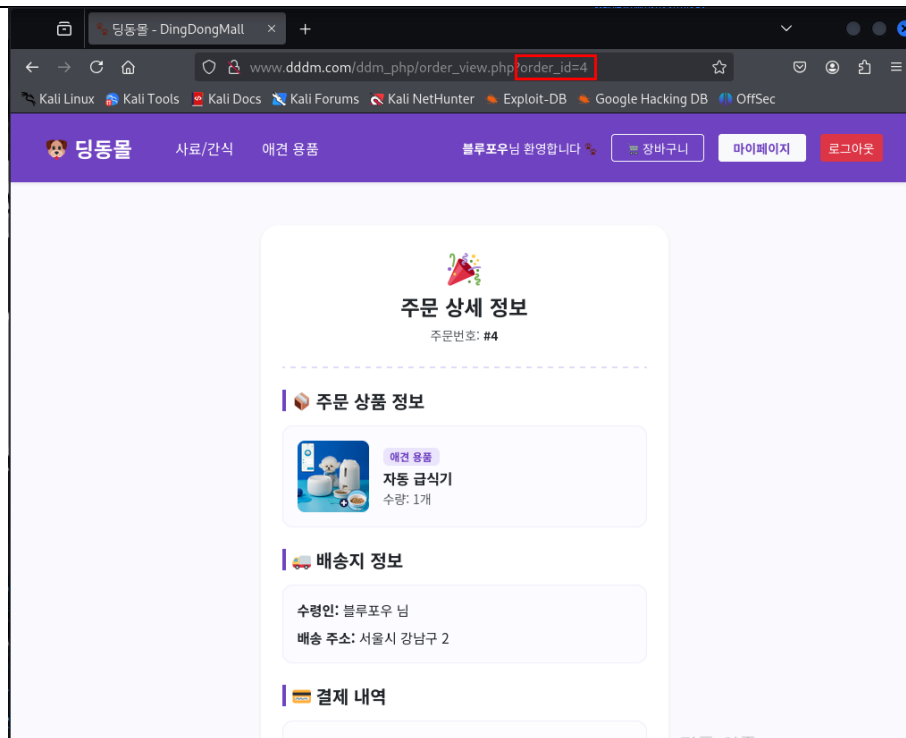


그림 3.3-2. 본인 주문 페이지 접근

### 3. 타인 파라미터 변조 테스트

URL 주소 창 끝의 파라미터를 타인(happy\_tails)의 주문 번호인 order\_id=1로 수동 변조하여 접근을 시도하였고, 권한이 없는 타인의 주문 내역임에도 불구하고 화면에 '수령인: 해피 님', '배송 주소: 서울시 송파구 1' 등의 상세 결제 내역과 개인정보가 그대로 노출되는 것을 확인하였다

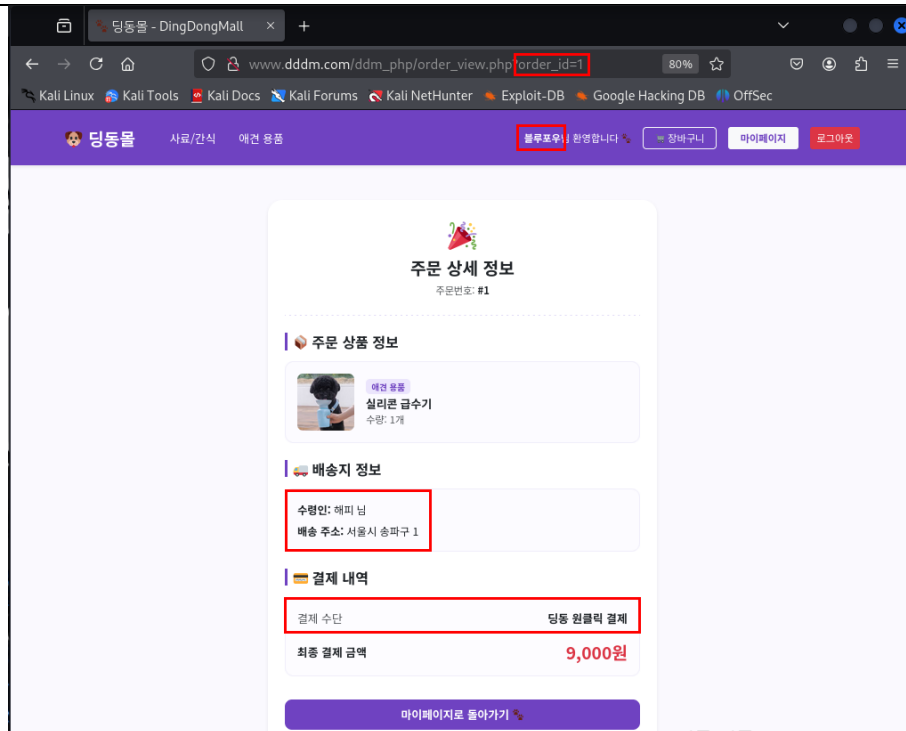


그림 3.3-3. 타인 파라미터 변조

| 영향도   | 영향             | 설명                                                                |
|-------|----------------|-------------------------------------------------------------------|
|       | 타인 개인정보 노출     | 수령인 이름, 배송지 주소, 결제 금액 등 민감한 거래 정보가 외부 사용자에게 무단 노출                 |
|       | 비인가 접근 및 수집    | 숫자를 순차적으로 증가시키는 자동화 공격(스크립트 등)을 통해 전체 회원의 주문 데이터를 대량으로 수집 가능      |
| 발생 원인 | 원인             | 설명                                                                |
|       | 서버 측 소유권 확인 부재 | 요청 데이터의 기본 키만 검증하고 세션 ID와의 매핑 확인 절차를 생략                           |
|       | 예측 가능한 식별자 사용  | 주문 번호가 순차적으로 증가하는 정수형 Primary Key 구조로 노출되어 있어 공격자가 구조를 추측하기 매우 용이 |

### 3.4. IDOR(장바구니 수량 변경)

| 구분 | 설명  |      |    |
|----|-----|------|----|
|    | URL | 파라미터 | 메뉴 |



|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |         |              |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|--------------|
| 발견URL       | http://www.dddm.com/ddm_php/cart.php<br>(proc/cart_update_proc.php)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | cart_id | 장바구니 -> 수량증가 |
| 취약점<br>상세내역 | 장바구니 번호(cart_id)가 데이터베이스에서 순차적으로 늘어나는 일련번호 형태로 되어 있고 수량 변경 처리 시 사용자 검증을 수행하지 않기 때문에, 타인의 cart_id 값을 지정하여 장바구니에 담긴 상품 수량을 임의로 변조할 수 있습니다.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |         |              |
| 시나리오        | <p>공격자</p> <p>POST 패킷 확보</p> <p>파라미터 변조</p> <p>변조된 데이터 값</p> <p>피해 사실 확인</p> <p>피해자</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |         |              |
| 재현<br>절차    | <p>1. 현재 Mariadb의 ddm_cart table 확인</p> <pre> MariaDB [ddm_db]&gt; select * from ddm_cart; +-----+-----+-----+-----+   cart_id   user_id   product_id   cart_quantity   +-----+-----+-----+-----+   6   with_dogs   19   1     7   with_dogs   16   1     8   happy_tails   1   1     9   blue_paw   9   1     10   blue_paw   17   2   +-----+-----+-----+-----+ 5 rows in set (0.006 sec) </pre> <p>그림 3.4-1. ddm_cart table 확인</p> <p>2. 본인 요청 패킷 캡처</p> <p>blue_paw 계정으로 장바구니 변경을 수행하면서 Burp Suite를 통해 발생하는 POST 패킷을 확보하였다.</p> <p>그림 3.4-2. 본인 요청 패킷 캡처</p> <p>3. 파라미터 변조 및 전송</p> <p>Repeater 툴에서 cart_id 값을 타인인 happy_tails 회원의 번호인 8로 바꾸고 수량을 100으로 변조(cart_id=8&amp;cart_quantity=100)하여 서버로 전송하였고, HTTP/1.1 302 Found</p> |         |              |

및 Location: cart.php로 정상 이동 응답을 반환하는 것을 확인하였다.

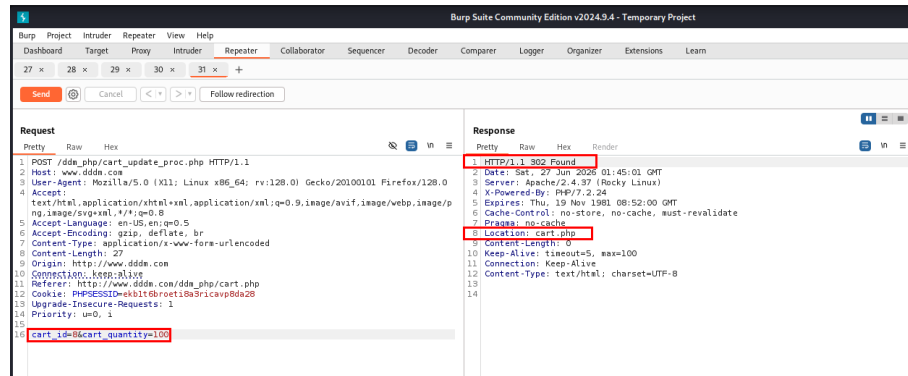


그림 3.4-3. 파라미터 변조 및 전송

4. copy로 url 복사해 kali에서 사용중인 브라우저로 접속

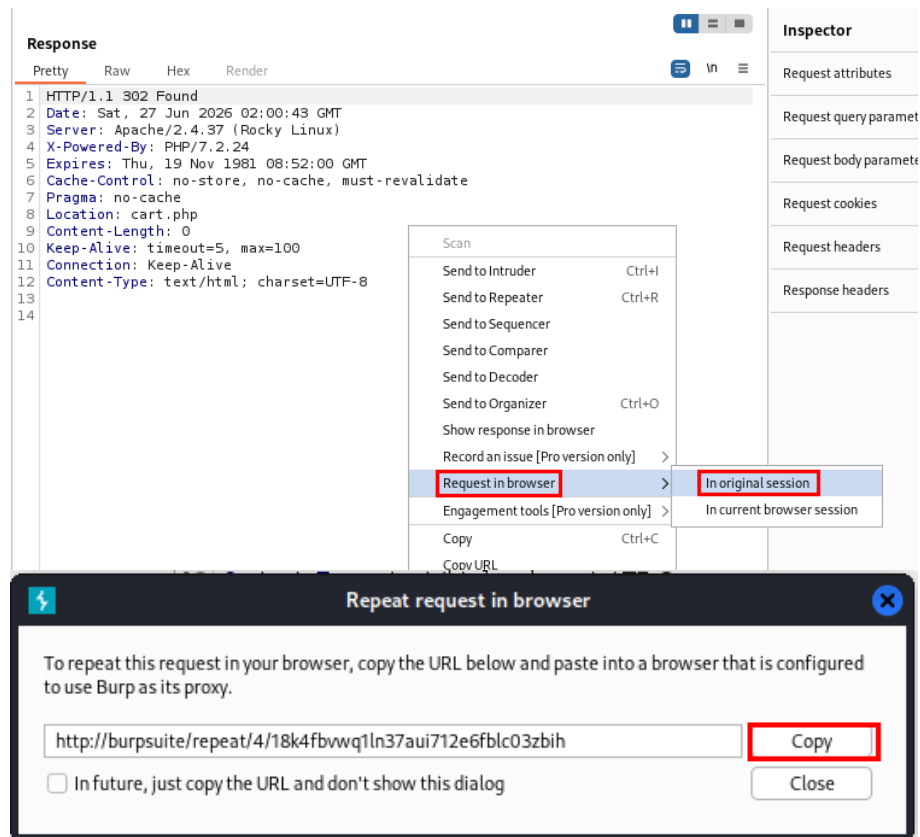


그림 3.4-4. 2. copy로 url 복사해 kali에서 사용중인 브라우저로 접속

5. 변조 결과 확인

해당 cart\_id(8번)를 소유한 happy\_tails 회원 계정으로 접속하여 장바구니를 확인해 본

결과, 본인이 조작하지 않았음에도 '수제 간식' 상품의 수량이 100개로 강제 변경되어 결제 금액이 4,200,000원으로 늘어나 있는 취약점을 증명하였다.

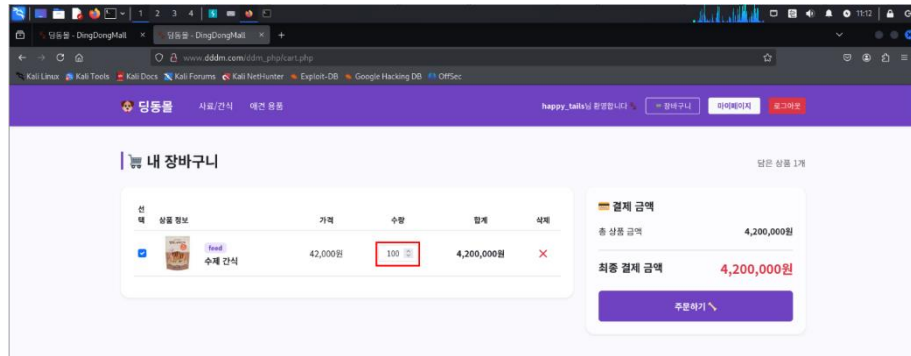
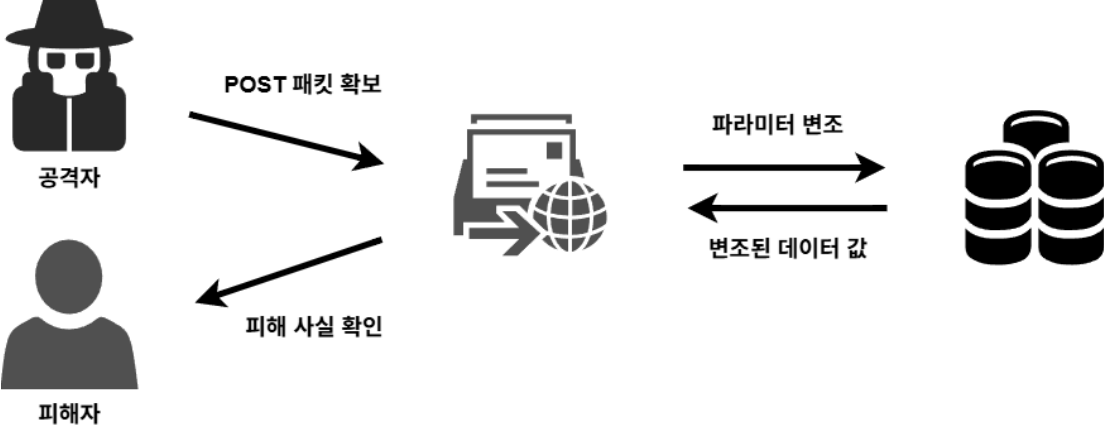


그림 3.4-6. 변조 결과 확인

| 영향도   | 영향              | 설명                                                                  |
|-------|-----------------|---------------------------------------------------------------------|
|       | 타인 서비스 데이터 위 변조 | 타인 장바구니의 물품 수량을 변경하거나 비정상적인 금액을 유도하여 정상적인 쇼핑몰 이용 및 주문 프로세스를 방해 가능   |
|       | 비인가 권한 악용       | 시스템 구조적 결함(순차적 PK)을 악용하여 다른 사용자의 쇼핑 행동 데이터 영역에 침범 가능                |
| 발생 원인 | 원인              | 설명                                                                  |
|       | 인증 및 소유권 체크 누락  | 수량 변경 API 요청 처리 시, 전달받은 cart_id가 현재 로그인한 세션 유저의 데이터인지 비교 검증하는 로직 누락 |
|       | 예측하기 쉬운 식별자 설계  | 데이터베이스의 Auto-Increment 기본 키(PK)가 외부에 정제 없이 그대로 노출되어 공격 타깃 설정이 매우 간편 |

### 3.5. IDOR(회원정보수정)

| 구분    | 설명                                                                        |             |               |
|-------|---------------------------------------------------------------------------|-------------|---------------|
| 발견URL | URL                                                                       | 파라미터        | 메뉴            |
|       | http://www.dddm.com/ddm_php/mypage_update.php<br>(proc/mypage_update.php) | user_number | 마이페이지 -> 정보수정 |

|                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|---------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>취약점<br/>상세내역</b> | <p>마이페이지에서 개인정보를 수정하여 전송할 때, 세션 정보에 기반하지 않고 클라이언트가 변조할 수 있는 파라미터(user_number)를 기반으로 대상을 식별합니다. 이 때문에 개발자 도구나 프록시 툴로 회원 식별 번호를 타인의 값으로 조작하여 전송하면 시스템이 타인의 개인정보를 강제로 변조시킵니다.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>시나리오</b>         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <b>재현<br/>절차</b>    | <p>1. 회원정보 수정 시 POST 패킷 확인</p> <p>회원정보 수정 폼을 제출할 때 발생하는 POST 패킷 데이터를 확인한 결과, 닉네임, 이메일, 주소 등이 파라미터로 전송되는 구조를 파악하였다.</p> <pre> Request Pretty Raw Hex 1 POST /ddm_php/mypage_update.php HTTP/1.1 2 Host: www.dddm.com 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/p ng,image/svg+xml,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Content-Type: application/x-www-form-urlencoded 8 Content-Length: 133 9 Origin: http://www.dddm.com 10 Connection: keep-alive 11 Referer: http://www.dddm.com/ddm_php/mypage.php 12 Cookie: PHPSESSID=ekb1t6broeti8a3ricavp8da28 13 Upgrade-Insecure-Requests: 1 14 Priority: u=0, i 15 16 user_nickname=%ED%95%B4%ED%94%BC&amp;user_email=happytails%40ddd.com&amp;user_address= %EC%84%9C%EC%9A%B8%EC%8B%9C+%EA%B0%95%EB%82%A8%EA%B5%AC </pre> <p><b>그림 3.5-1. 회원정보 수정 시 POST 패킷</b></p> <p>2. 파라미터 주입 및 변조</p> <p>Request 패킷의 body 하단에 원하는 수정 데이터 값(user_nickname=hacking, user_email=hacking@ddd.com, user_address=hacking_success)들을 세팅하고, 맨 마지막에 타인의 고유 번호인 user_number=3을 수동으로 삽입하여 서버로 전송하였다.</p> |

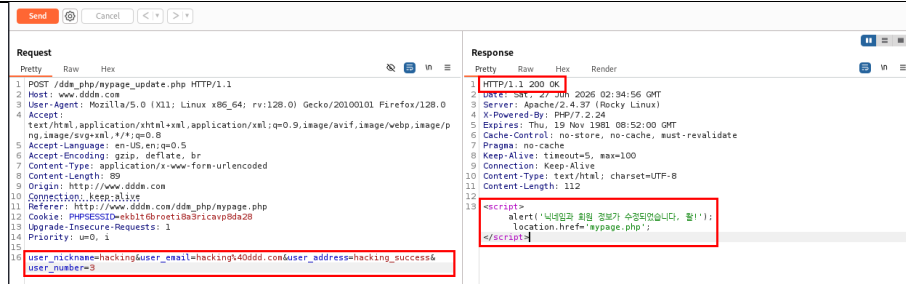


그림 3.5-2. 파라미터 주입 및 변조

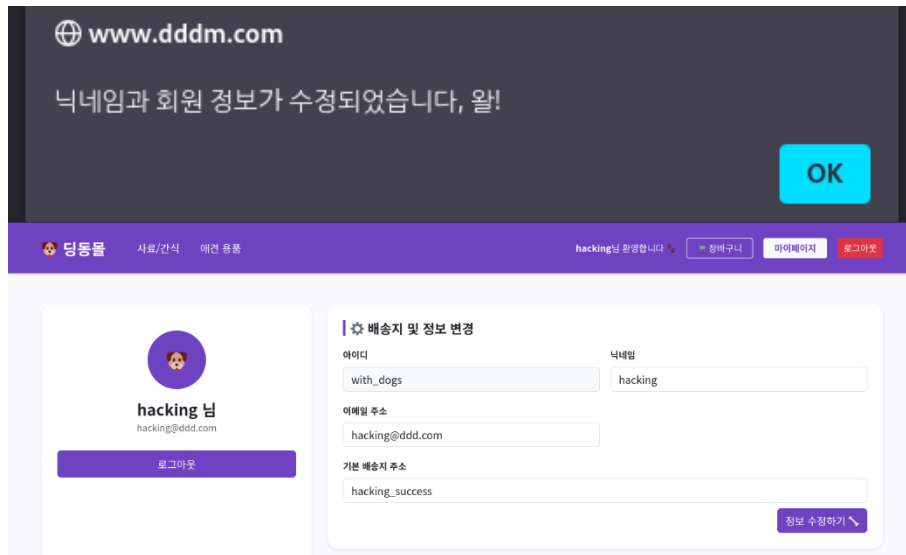


그림 3.5-3. 공격받은 피해자 정보

### 3. 공격 결과 및 DB 검증

ddm\_db 테이블에서 user\_number=3 번 계정은 아이디 with\_dogs, 닉네임 '함께걷기'였으나, 공격 패킷 전송 후 데이터베이스를 다시 조회한 결과 닉네임이 hacking, 주소가 hacking\_success 등으로 완전하게 강제 변조된 것을 확인하였다.

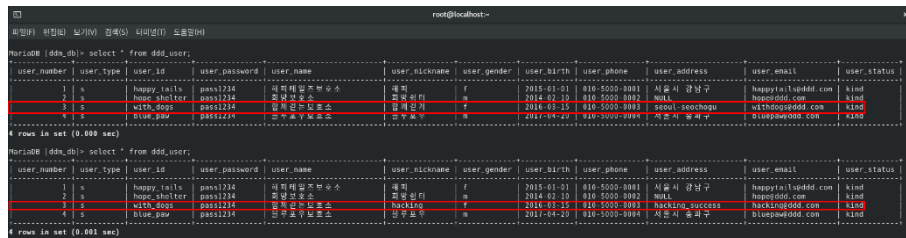


그림 3.5-4. 공격 결과 및 DB 검증

| 영향도      | 영향                    | 설명                                                                                                                         |
|----------|-----------------------|----------------------------------------------------------------------------------------------------------------------------|
|          | 대규모 계정 정보 위 변조        | 무작위 대입 공격(Id/Number Brute-Forcing)을 수행할 경우 시스템 내 전체 회원의 개인정보(이메일, 배송지 등)를 일괄적으로 훼손하거나 변조 가능                                |
|          | 2차 피해 연계              | 타인의 이메일이나 주소를 공격자의 정보로 변조해 가로챈 후 비밀번호 찾기 기능 등을 통해 계정을 완전히 탈취하는 연계 공격이 발생 가능                                                |
| 발생<br>원인 | 원인                    | 설명                                                                                                                         |
|          | 클라이언트 입력 값에 의존한 유저 식별 | 안전한 서버 세션 정보(\$_SESSION['user_id'] 등)를 기준으로 수정 대상 쿼리를 실행하지 않고, 클라이언트가 조작 가능한 파라미터(user_number)를 그대로 WHERE 절 조건문 등에 신뢰하여 사용 |
|          | 서버 측 검증 부재            | 전달받은 user_number 객체에 대해 수정 권한이 있는지 소유권 검증 절차가 없음                                                                           |

### 3.6. 파일 업로드 취약점 (Unrestricted File Upload)

| 구분          | 설명                                                                                          |      |                             |
|-------------|---------------------------------------------------------------------------------------------|------|-----------------------------|
| 발견URL       | URL                                                                                         | 파라미터 | 메뉴                          |
|             | http://www.dddm.com/ddm_php/product_add.php<br>(product_add_proc.php)                       | cmd  | 메인 페이지(관리자 로그인 상태) -> 상품 등록 |
| 취약점<br>상세내역 | 파일 업로드 기능에서 서버측 확장자 검증 로직 미흡을 통한 악의적인 웹셸 파일을 업로드 하여 공격자는 업로드 된 웹셸 경로에 직접 접근하여 시스템 명령을 실행합니다 |      |                             |

|                  |                                                                                                                                                                                                                                                                                                                                                                                                   |
|------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>시나리오</p>      | <p>파일 업로드</p> <p>공격자</p> <p>웹 서버</p> <p>업로드 디렉터리</p> <p>웹셸</p> <p>System('who ami')</p> <p>공격자 명령 전송</p> <p>서버 결과 반환</p> <p>apache @ server</p>                                                                                                                                                                                                                                                   |
| <p>재현<br/>절차</p> | <p>1. product_add.php 페이지에서 파일 업로드 기능을 통해 shell.php 업로드</p> <p>상품 등록</p> <p>상품명<br/>dogg tuna</p> <p>카테고리<br/>사료/간식</p> <p>가격<br/>10000</p> <p>상품 이미지<br/>Browse... shell.php</p> <p>상세 설명</p> <p>등록하기</p> <p>그림 3.5-1. Shell.php 파일 업로드</p> <p>2. 파일 업로드 요청 및 응답 패킷 확인</p> <p>해당 요청에 대해 웹 서버가 별도의 차단 없이 파일 업로드 요청을 정상적으로 처리하였으며, 서버로부터 '200 OK' 응답 코드를 수신함으로써 웹셸 파일이 정상적으로 업로드 되었음을 확인하였습니다.</p> |

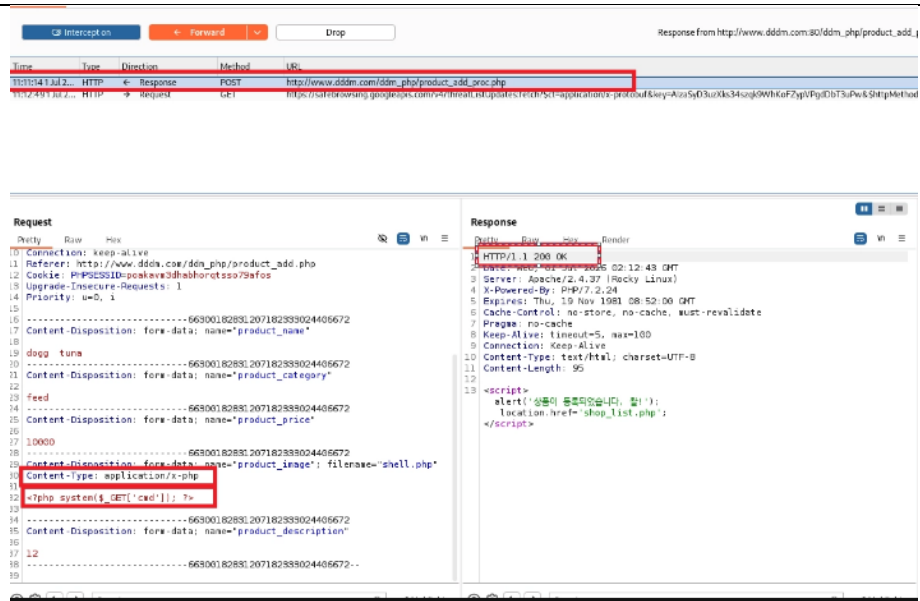


그림 3.5-2. 파일 업로드 요청 및 응답 패킷

### 3. 파일 업로드 성공 확인

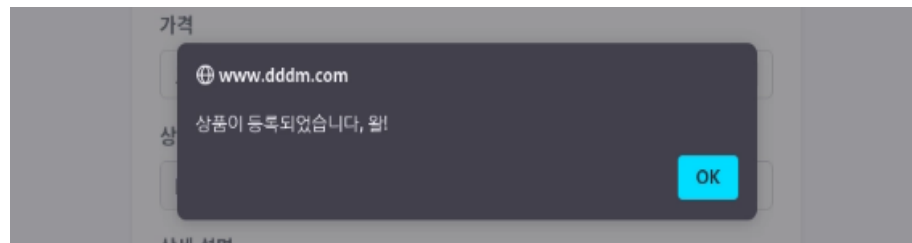


그림 3.5-3. 파일 업로드 성공

### 4. 파일 업로드 저장 위치 확인

공격자가 개발자 도구를 이용하여 업로드 된 파일의 저장 경로를 확인

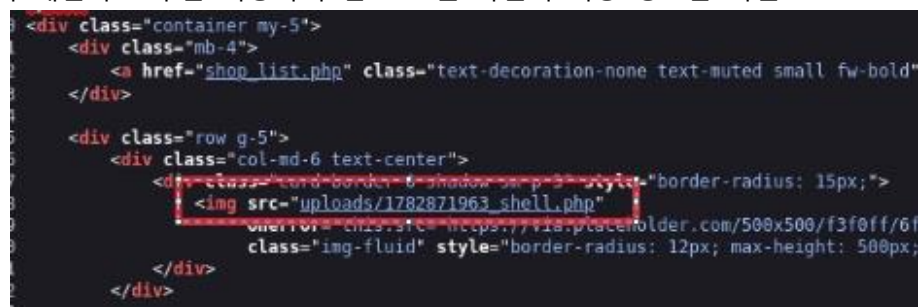


그림 3.5-4. 파일 업로드 저장 위치



## 5. 서버 정보 탈취

공격자가 업로드 된 파일의 저장 경로에 직접 접속한 후, URL의 cmd 파라미터를 이용하여 시스템 명령어를 전달하고, 서버의 중요 파일인 /etc/passwd의 계정 정보를 확인하였습니다.

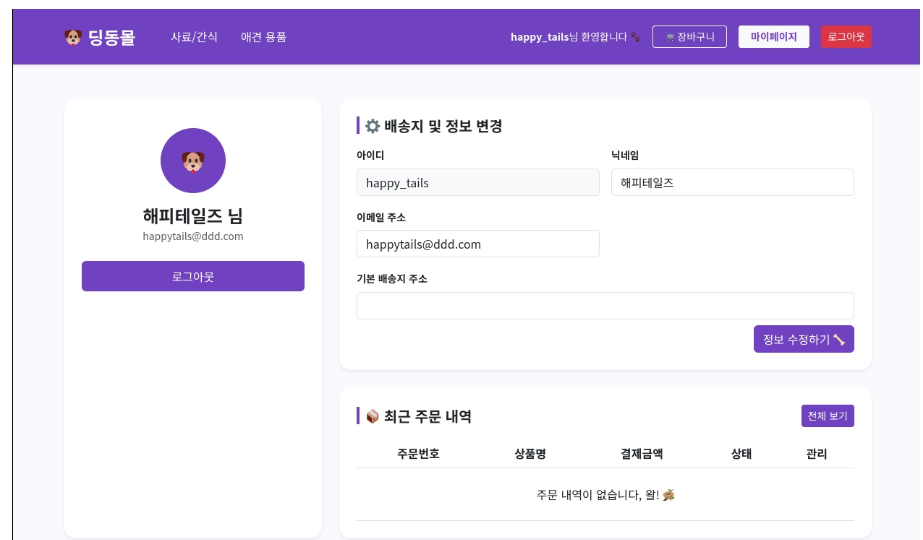
```

2 bin:x:1:1:bin:/bin:/sbin/nologin
3 daemon:x:2:2:daemon:/sbin:/sbin/nologin
4 adm:x:3:4:adm:/var/adm:/sbin/nologin
5 lp:x:4:7:p:/var/spool/lpd:/sbin/nologin
6 sync:x:5:0:sync:/sbin:/bin/sync
7 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
8 halt:x:7:0:halt:/sbin:/sbin/halt
9 mail:x:8:2:mail:/var/spool/mail:/sbin/nologin
10 operator:x:11:0:operator:/root:/sbin/nologin
11 games:x:12:100:games:/usr/games:/sbin/nologin
12 ftp:x:14:0:FTP User:/var/ftp:/sbin/nologin
13 nobody:x:65534:65534:Kernel Overflow User:/sbin/nologin
14 dbus:x:81:81:system message bus:/sbin/nologin
15 systemd-coredump:x:999:997:systemd Core Dumper:/sbin/nologin
16 systemd-resolve:x:193:193:systemd Resolver:/sbin/nologin
17 tss:x:59:0:Account used for TPM access:/sbin/nologin
18 polkitd:x:998:996:User for polkitd:/sbin/nologin
19 geoclue:x:997:995:User for geoclue:/var/lib/geoclue:/sbin/nologin
20 unbound:x:996:992:Unbound DNS resolver:/etc/unbound:/sbin/nologin
21 rtkit:x:12:172:RealtimeKit:/proc:/sbin/nologin
22 pipewire:x:995:991:Pipewire System Daemon:/var/run/pipewire:/sbin/nologin
23 pulse:x:11:171:PulseAudio System Daemon:/var/run/pulse:/sbin/nologin
24 dnsmasq:x:988:988:Dnsmasq DHCP and DNS server:/var/lib/dnsmasq:/sbin/nologin
25 qemu:x:107:107:qemu user:/sbin/nologin
26 clevis:x:687:987:Clevis Decryption Framework unprivileged user:/var/cache/clevis:/sbin/nologin
27 usbmuxd:x:113:113:usbmuxd user:/sbin/nologin
28 gluster:x:986:986:GlusterFS daemons:/run/gluster:/sbin/nologin
29 rpcbind:x:32:32:Rpcbind Daemon:/var/lib/rpcbind:/sbin/nologin
30 chrony:x:85:985:/var/lib/chrony:/sbin/nologin
31 setroubleshoot:x:984:983:/var/lib/setroubleshoot:/sbin/nologin
32 saslauthd:x:983:76:Saslauthd user:/run/saslauthd:/sbin/nologin
33 libstoragemgmt:x:982:982:daemon account for libstoragemgmt:/var/run/lsm:/sbin/nologin
34 sssd:x:981:981:User for sssd:/sbin/nologin
35 cockpit-ws:x:980:979:User for cockpit web service/nonexisting:/sbin/nologin
36 cockpit-ws-instances:x:978:978:User for cockpit-ws instances/nonexisting:/sbin/nologin
37 flatpak:x:978:977:User for flatpak system helper:/sbin/nologin
38 colord:x:77:976:User for colord:/var/lib/colord:/sbin/nologin
39 rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
40 gdm:x:42:2:/var/lib/gdm:/sbin/nologin
41 gnome-initial-setup:x:976:975:/run/gnome-initial-setup:/sbin/nologin
42 sshd:x:74:74:Privilege-separated SSH:/var/empty/ssh:/sbin/nologin
43 avahi:x:70:70:Avahi mDNS/DNS-SD Stack:/var/run/avahi-daemon:/sbin/nologin
44 tcpdump:x:72:72:/sbin/nologin
45 admin:x:1000:1000:admin:/home/admin:/bin/bash
46 apache:x:8:48:Apache:/usr/share/httpd:/sbin/nologin
47 mysql:x:2:27:MySQL Server:/var/lib/mysql:/sbin/nologin
48 ngnix:x:9:5:974:Nginx web server:/var/lib/nginx:/sbin/nologin
  
```

그림 3.5-5. 서버의 정보 탈취 결과

| 영향도   | 영향                       | 설명                                                               |
|-------|--------------------------|------------------------------------------------------------------|
|       | 시스템 제어권 탈취               | 공격자가 서버의 운영체제에서 임의의 시스템 명령어를 실행할 수 있으며, 서버에 대한 완전한 제어권을 획득할 수 있음 |
|       | 데이터 유출 및 파괴              | 서버 내 저장된 파일을 고의적으로 삭제하거나 변조할 수 있음                                |
| 발생 원인 | 원인                       | 설명                                                               |
|       | 확장자 미검증                  | 파일 업로드 시 확장자에 대한 필터링 없이 업로드를 허용하고 있음                             |
|       | 실제 파일의 내용과 관계없이 업로드 받아들임 | Content-Type 헤더 신뢰                                               |

### 3.6. CSRF

| 구분          | 설명                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |                             |                 |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|-----------------|
| 발견URL       | URL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | 파라미터                        | 메뉴              |
|             | http://www.dddm.com/ddm_php/mypage.php<br>(proc/mypage_update.php)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | user_nickname<br>user_email | 메인 페이지 -> 마이페이지 |
| 취약점<br>상세내역 | <p>사용자가 로그인한 상태에서 마이페이지의 정보를 수정할 때, 서버는 사용자의 세션 쿠키만을 확인합니다. 따라서 공격자는 사용자가 인지하지 못하는 사이에 의도하지 않은 정보 수정 요청을 서버로 전송하여, 사용자의 정보를 변경할 수 있습니다..</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                             |                 |
| 시나리오        |  <p>The diagram illustrates a CSRF attack scenario. On the left, an attacker (공격자) wearing a hat and mask is shown. In the center, a victim (피해자) is shown in a logged-in state (로그인 상태에서 공격자의 페이지 접속). On the right, a web server (웹 서버) is shown. Arrows indicate the flow of the attack: 1. The attacker sends a page connection request (페이지 접속 유도) to the victim. 2. The victim, while logged in, sends a request to the web server (요청 처리완료(공격 성공)). 3. The web server responds with a session cookie (위조된 요청 전송(사용자의 쿠키)).</p>                                                           |                             |                 |
| 재현<br>절차    | <p>1. 기존 마이페이지</p>  <p>The screenshot shows a user profile page for '해피테일즈 님' (happy_tails). It includes fields for ID (happy_tails), nickname (해피테일즈), email (happytails@ddd.com), and a basic shipping address. There is a '로그아웃' (Logout) button and a '정보 수정하기' (Edit Info) button. Below the profile, there is a section for '최근 주문 내역' (Recent Order History) with columns for order number, product name, payment amount, status, and management. The message '주문 내역이 없습니다, 왓!' (No order history, wat!) is displayed.</p> <p>그림 3.6-1. 기존 마이페이지</p> <p>2. mypage.php 요청 시 세션 쿠키 확인</p> |                             |                 |

mypage.php 요청 시 PHPSESSID 세션 쿠키가 자동으로 포함되어 전송되는 것을 확인하였다. 이는 로그인한 사용자의 인증 상태가 세션 쿠키를 통해 유지되고 있음을 의미하고 있습니다.

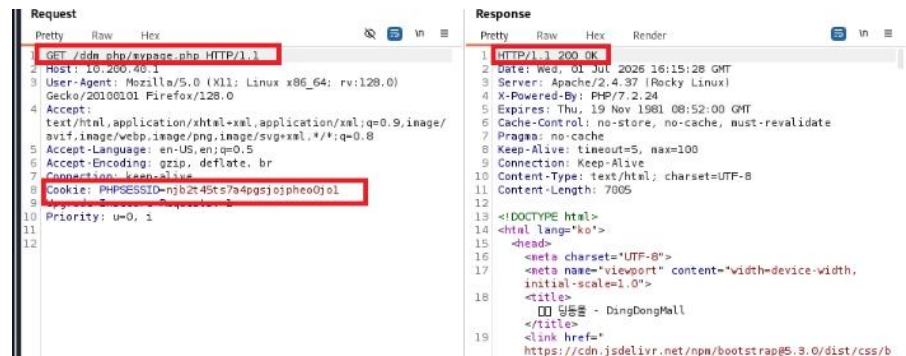


그림 3.6-2 사용자의 쿠키 확인

3. 자신의 컴퓨터에 임시 웹 서버를 구축하여 공격용 파일(attack.html)을 서비스함



그림 3.6-3 임시 웹 서버 구축

4. 사용자의 세션 쿠키를 통한 요청

Origin 및 Referer 헤더 값이 10.200.40.66 으로 기록되어 있으며, 요청의 출처가 대상 서버가 아닌 공격자가 구축한 웹 서버임을 확인할 수 있습니다. 또한 브라우저의 자동 쿠키 전송 특성을 악용하여 사용자의 세션 쿠키가 함께 전송되므로, 공격자가 사용자의 인증된 상태를 이용하여 요청을 수행할 수 있음을 보여주고 있습니다.

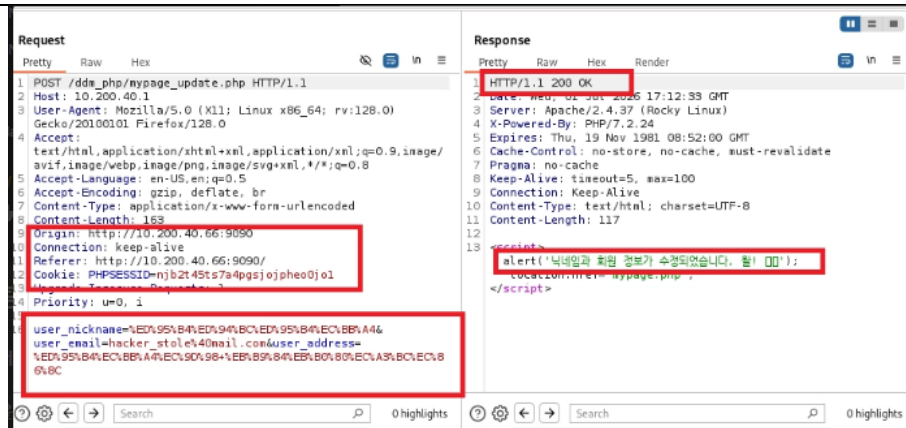


그림 3.6-4 사용자의 쿠키를 통한 요청

## 5. 사용자의 변동된 마이페이지 결과

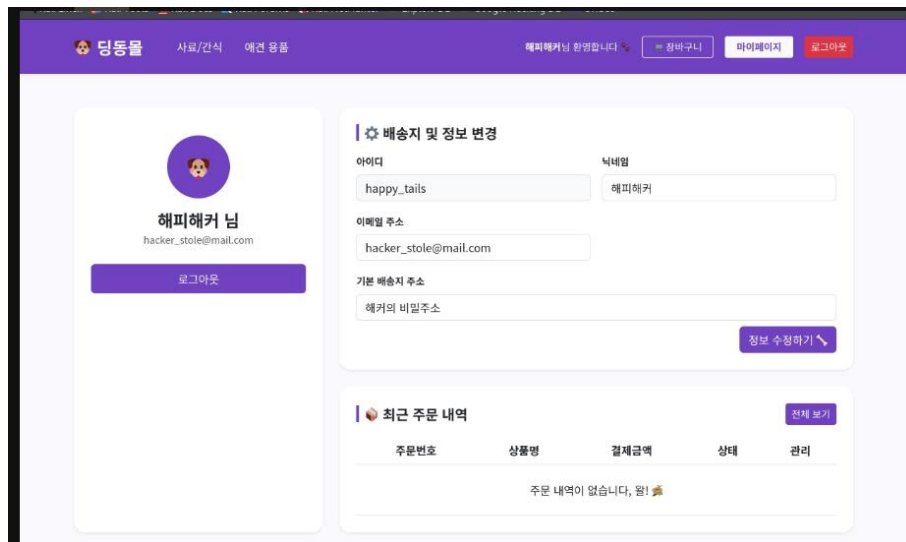


그림 3.6-5 변동된 사용자의 마이페이지

| 영향도 | 영향          | 설명                                            |
|-----|-------------|-----------------------------------------------|
|     | 사용자 권한 도용   | 인증된 사용자의 브라우저 세션을 악용하여 사용자 몰래 원치 않는 요청을 수행함   |
| 발생  | 원인          | 설명                                            |
|     | 데이터 변조 및 탈취 | 타깃 서버의 개인정보 수정, 비밀번호 변경 등 민감한 데이터의 조작 및 탈취 가능 |

|           |             |                                                                                                                         |
|-----------|-------------|-------------------------------------------------------------------------------------------------------------------------|
| <b>원인</b> | 인증 상태 자동 전송 | 웹 브라우저의 기본 특성으로 인해, 타깃 서버에 요청할 경우 인증 쿠키가 자동으로 포함되어 전송됨.                                                                 |
|           | 요청 출처 검증 부재 | 요청 발생 시 사용자별 고유한 CSRF Token을 생성하고 검증하여 정상적인 요청 여부를 확인 HTTP 요청 헤더의 Origin 또는 Referer 값을 검증하여 신뢰할 수 있는 도메인에서 발생한 요청인지 확인. |

## 4. 보안 권고안

### 4.1. 세션 고정

|                                                                                                        |                                                                                                                       |
|--------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>취약점 항목</b>                                                                                          | 세션 고정                                                                                                                 |
| <b>취약점 개요</b>                                                                                          | 로그인할 때마다 예측 불가능한 새로운 세션ID를 발행하여 세션ID의 고정 사용을 방지하기 위함. 사용자 로그인 시 항상 일정하게 고정된 세션ID가 발행되는 경우 세션ID를 도용한 비인가자의 접근 및 우회가 가능 |
| <b>보안 조치 방법</b>                                                                                        |                                                                                                                       |
| 로그인할 때마다 예측 불가능한 새로운 세션ID를 발급받도록 해야 하고 기존 세션ID는 파기해야 함<br>세션ID의 만료시간 및 기간을 적절하게 설정하여 이후에도 남아있지 않도록 해야함 |                                                                                                                       |

### 4.2. SQL Injection

|                                                                                                                                                                                   |                                                                                                                        |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| <b>취약점 항목</b>                                                                                                                                                                     | SQL Injection                                                                                                          |
| <b>취약점 개요</b>                                                                                                                                                                     | 사용자로부터 입력 받은 데이터를 검증 없이 SQL 쿼리문에 직접 포함할 때 발생하는 취약점입니다. 공격자가 악의적인 SQL 구문을 입력하여 인증을 우회하거나 데이터베이스의 비공개 정보를 탈취/조작할 수 있습니다. |
| <b>보안 조치 방법</b>                                                                                                                                                                   |                                                                                                                        |
| 1. Prepared Statement(PDO) 사용: 동적 쿼리 대신 매개변수화 된 쿼리를 사용하여 입력 값이 쿼리 명령어로 실행되지 않도록 격리해야 합니다.<br>2. 입력 값 정제(Sanitization): 모든 사용자 입력 값에 대해 화이트리스트 기반의 검증을 수행하고, 특수문자를 이스케이프 처리해야 합니다. |                                                                                                                        |

### 4.3. IDOR

| 취약점 항목                                                                                                                                                                                                                                                            | IDOR                                                                                                                                                          |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 취약점 개요                                                                                                                                                                                                                                                            | 웹 애플리케이션이 개별 객체(주문 내역, 개인정보 등)에 접근할 때, 현재 로그인한 사용자가 해당 객체에 대한 접근 권한을 가지고 있는지 서버 측에서 확인하지 않을 때 발생합니다. 공격자가 URL 파라미터(예: order_id)를 수정하여 타인의 데이터를 무단 열람할 수 있습니다. |
| 보안 조치 방법                                                                                                                                                                                                                                                          |                                                                                                                                                               |
| <ol style="list-style-type: none"> <li>1. 소유권 검증 로직 구현: 데이터 조회 쿼리 실행 시 WHERE 절에 현재 세션의 사용자 식별 값(user_id 등)을 반드시 포함하여 본인의 데이터만 접근 가능하도록 제한해야 합니다.</li> <li>2. 간접 참조 사용: 데이터베이스의 실제 기본 키(PK)를 직접 노출하지 않고, 추측 불가능한 해시 값이나 매핑 된 임의의 식별자를 사용하여 경로를 숨겨야 합니다.</li> </ol> |                                                                                                                                                               |

### 4.4. 파일 업로드 취약점

| 취약점 항목                                                                                                                                                                                                                                     | 파일 업로드 취약점                                                                                                         |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| 취약점 개요                                                                                                                                                                                                                                     | 서버가 파일 업로드 과정에서 확장자 및 파일 형식에 대한 검증을 수행하지 않거나, 업로드 된 파일에 실행 권한을 부여함으로써 공격자가 악성 웹셸(Web Shell)을 서버에 업로드하고 실행할 수 있습니다. |
| 보안 조치 방법                                                                                                                                                                                                                                   |                                                                                                                    |
| <ol style="list-style-type: none"> <li>1. 화이트리스트 방식을 사용하여 허용된 확장자만 업로드 되도록 제한해야 합니다.</li> <li>2. 업로드 된 파일의 MIME 타입과 실제 내용(Magic Number)을 검사해야 합니다.</li> <li>3. 업로드 디렉터리에 파일의 실행 및 직접 접근을 제거하고 파일명을 무작위로 변경하여 실행 및 접근을 방지해야 합니다.</li> </ol> |                                                                                                                    |

### 4.5 CSRF

| 취약점 항목                                                                                                                                                                                           | CSRF (사이트 간 요청 위조)                                                                     |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|
| 취약점 개요                                                                                                                                                                                           | 공격자가 악의적으로 구성된 페이지를 통해 사용자의 권한을 도용하여 타겟 서버에 비정상적인 요청(개인정보 수정 등)을 자동으로 전송하도록 유도하고 있습니다. |
| 보안 조치 방법                                                                                                                                                                                         |                                                                                        |
| <ol style="list-style-type: none"> <li>1. 요청 발생 시 사용자의 고유한 CSRF Token을 생성 및 검증하여 정상적인 요청인지 확인해야 합니다.</li> <li>2. HTTP 요청 헤더의 Origin 또는 Referer 값을 확인하여 신뢰할 수 있는 도메인에서의 요청인지 검증해야 합니다.</li> </ol> |                                                                                        |